Meridian Studios LLC

Data Retention and Disposal Policy

Written 2026-09-26 · Exported for Plaid production review 2026-09-26

This document is the data retention and disposal policy of Meridian Studios LLC (the "Company"). It states how long each category of data is kept, why, and how it is destroyed when its time is up. The retention schedule below is the same one published to consumers in the privacy policy at `meridiancash.io/privacy`; this document adds the operational detail — the backups, the audit records, and the disposal mechanics — that the consumer document summarizes. It accompanies the Company's Information Security Policy and is maintained in the product's version-controlled repository; when the system changes, this document is updated in the same commit.

Every statement in this document is accurate as written, or names a planned change and its date.

1. Principles

Data is kept only while it serves the consumer or a legal duty, and every category below names which. Nothing is retained for advertising, resale, or analytics beyond the service itself. Disposal is by deletion from the live database and by rotation out of encrypted backups; no category is kept indefinitely except the audit record, whose purpose requires it and whose content is minimal.

2. Retention schedule

2.1 The ledger — bank and brokerage accounts, balances, transactions, holdings — is kept for as long as the account is open. It exists solely to render the consumer's own finances back to them.

2.2 A disconnected institution. Removing a bank deletes the accounts, transactions, and holdings that came through it, immediately, and revokes the Plaid access token that read it.

2.3 A closed account is deleted from the live database within 30 days and is gone from encrypted backups within 90 days as those rotate. Deletion is end to end: the ledger, the Plaid Items (removed at Plaid, which invalidates the tokens), and the Stripe customer.

2.4 Sign-in codes live for ten minutes, then expire and are deleted. They are stored only as hashes while they live.

2.5 Sessions are kept until the consumer signs out, which deletes the row, or until they expire at 90 days. Tokens are stored only as hashes.

2.6 Request logs are kept up to 90 days. Logs never contain credentials: a secret or access token is logged as its length, never its value.

2.7 Invoices and tax records are kept as long as tax law requires, usually several years, held at the billing processor (Stripe) and separate from the ledger.

2.8 The audit record. An append-only audit table records every response that served consumer data — whose data, what data, from what address, when — and every backup. Its rows survive account deletion by design: the record of who accessed data must outlive the data, or a breach investigation after a deletion has nothing to consult. The table holds access metadata only, never the financial data itself, and refuses `UPDATE` and `DELETE` statements.

3. Backups

A daily database dump is encrypted on the server with a public key the server cannot decrypt with, and uploaded to object storage with 30-day retention, after which the storage provider deletes it. Weekly server

snapshots and a manually refreshed encrypted offline copy are the second and third copies. This rotation is what bounds the backup lifetime of deleted data: a row deleted from the live database is out of every backup within 90 days, as published in the privacy policy.

4. Disposal

4.1 Live data is disposed of by deletion from the database, on the schedule of section 2.

4.2 Backups are disposed of by rotation: each encrypted dump is deleted by the storage provider at 30 days, and snapshots age out on their provider's schedule. Because every off-server copy is encrypted under keys the storage never holds, destruction of a key is destruction of every copy it sealed, and a copy that escapes rotation is ciphertext.

4.3 Physical media. Production hardware is owned and operated by DigitalOcean; disposal of physical media is delegated to DigitalOcean and inherited from its compliance program. The database volume is block-encrypted, so decommissioned hardware does not hold plaintext. Server snapshots taken before the volume encryption migration of 2026-09-21 hold plaintext until they age out, by 2026-10-19.

4.4 Consumer-initiated deletion is self-serve: closing the account in the application requires a confirmation and a fresh emailed six-digit code, so a stolen session alone cannot destroy an account. The deletion path is verified by automated server-side tests. A consumer may also request closure by email, per the privacy policy.

5. Enforcement and review

The retention schedule is enforced by the system, not by calendar reminders: expiries are checked at use, deletion cascades are code, and backup rotation is the storage provider's retention setting. Every backup — each of which reads all data — lands in the append-only audit record. This policy is reviewed with the rest of the security program at every Plaid milestone and at least yearly, and each review is dated. It complies with the retention and deletion commitments published to consumers, and with the GLBA Safeguards Rule's disposal expectations, which govern the Company as a financial data holder.